

# STRIDE THREAT MODEL ANALYSIS REPORT

Student Name: Solomon Mwaura | Date: March  
15, 2026

## 1. System Overview and Scope

**System Description:** The AutoDrive connected vehicle platform is a mission-critical infrastructure managing telemetry data, remote diagnostics, and Over-the-Air (OTA) firmware updates for autonomous and connected vehicles. Hosted on AWS, the system ensures vehicle safety, real-time performance monitoring, and encrypted communication between the global vehicle fleet and the cloud backend.

### Key Components in Scope:

- **Vehicle Authentication System:** Multi-Factor Authentication (MFA) and Digital Certificates.

- **Vehicle Telemetry & Data Management:** Secure Cloud Databases for diagnostics.
- **OTA Software Update System:** Firmware signing and secure deployment pipelines.
- **Secure Messaging System:** Encrypted Cloud-to-Vehicle communication.
- **Third-Party REST API:** Partner integrations secured via OAuth and API Keys.

## 2. System Components Breakdown

| COMPONENT       | TECHNICAL DESCRIPTION                                                                      |
|-----------------|--------------------------------------------------------------------------------------------|
| Authentication  | Digital certificates for vehicles; MFA for diagnostics; password reset for fleet managers. |
| Data Storage    | Cloud-based database for engine diagnostics and performance metrics (AES-256 encryption).  |
| Communication   | Secure messaging protocols (TLS 1.2/1.3) and encrypted OTA firmware delivery.              |
| API Integration | REST API for partners using OAuth and API keys with strict rate limiting.                  |

### 3. STRIDE Threat Identification

| COMPONENT        | STRIDE CATEGORY        | THREAT DESCRIPTION                                                                       |
|------------------|------------------------|------------------------------------------------------------------------------------------|
| Authentication   | Spoofing               | Credential stuffing targeting fleet manager accounts or faking vehicle certificates.     |
| OTA System       | Tampering              | An attacker modifies firmware before deployment or during a malicious rollback.          |
| Messaging System | Repudiation            | A malicious actor sends a false emergency alert and logs are deleted to hide the origin. |
| Telemetry Data   | Information Disclosure | Interception of unencrypted telemetry or unauthorized access to the cloud database.      |
| Authentication   | Denial of Service      | Traffic spikes (DoS) aimed at authentication services to prevent vehicle connectivity.   |

| COMPONENT       | STRIDE CATEGORY        | THREAT DESCRIPTION                                                                    |
|-----------------|------------------------|---------------------------------------------------------------------------------------|
| Third-Party API | Elevation of Privilege | Exploiting API misconfigurations to gain administrative control over vehicle updates. |

## 4. Risk Assessment and Impact

| THREAT DESCRIPTION                       | STRIDE CATEGORY   | LIKELIHOOD | IMPACT | OVERALL RISK |
|------------------------------------------|-------------------|------------|--------|--------------|
| Credential stuffing on MFA accounts      | Spoofing          | High       | High   | CRITICAL     |
| Firmware/ Update tampering               | Tampering         | Medium     | High   | HIGH         |
| Traffic spikes causing connectivity loss | DoS               | High       | Medium | HIGH         |
| Unauthorized access to telemetry         | Info Disclosure   | Medium     | Medium | MEDIUM       |
| API key/ OAuth token theft               | Elevation of Priv | Medium     | High   | HIGH         |

## 5. Mitigation Strategies

| THREAT CATEGORY        | MITIGATION STRATEGY                                                                         |
|------------------------|---------------------------------------------------------------------------------------------|
| Spoofing               | Implement Account Lockout policies and behavior-based anomaly detection for logins.         |
| Tampering              | Use Hardware Security Modules (HSM) for code signing; verify hashes before installation.    |
| Denial of Service      | Deploy AWS Shield/WAF and implement auto-scaling for authentication endpoints.              |
| Information Disclosure | Enforce strict IAM policies (Least Privilege) and rotate encryption keys regularly.         |
| Elevation of Privilege | Implement granular OAuth scopes and strict input validation/sanitization for all API calls. |

## 6. Summary and Recommendations

### Top Three Critical Threats:

- Firmware Tampering:** A successful OTA exploit could allow physical control over vehicle braking or steering, posing a direct threat to human life.

2. **Denial of Service (DoS):** Traffic spikes overwhelming authentication prevent vehicles from receiving critical safety alerts, leaving the fleet vulnerable.
3. **Credential Spoofing:** Unauthorized access to fleet manager accounts could lead to mass data theft or unauthorized remote diagnostics.

### **Final Strategic Recommendations:**

- **Zero Trust Architecture:** Move toward a model where every API call and vehicle message is continuously verified.
- **Automated Log Analysis:** Implement an AI-driven SIEM system to detect anomalous patterns in real-time.
- **Hardened OTA Process:** Ensure rollback versions are cryptographically signed and stored in immutable storage.
- **API Security Audit:** Conduct quarterly penetration testing specifically on the REST API to identify misconfigurations.